

HiveForce Labs

THREAT ADVISORY



ATTACK REPORT

A Modular AlienFox Toolkit Used in Cloud-Based Email and Web Hosting Service Attacks

Date of Publication

April 04, 2023

Admiralty Code

A2

TA Number

TA2023168

Summary

Attack began: March 2023

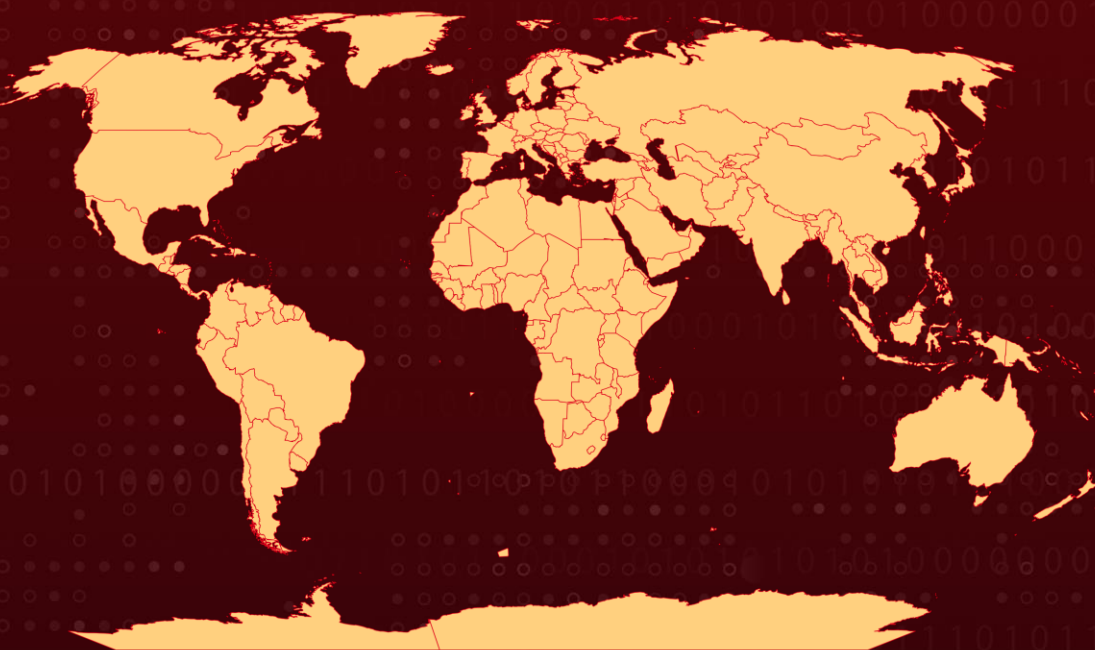
Toolkit: AlienFox

Attack Region: Worldwide

Targeted Industries: Telecom, Pharmaceuticals, Financial, Technology

Attack: AlienFox is a toolkit used by attackers to target email and web hosting services, particularly cloud-based and software-as-a-service (SaaS) email hosting services

Attack Regions



Powered by Bing
© Australian Bureau of Statistics, GeoNames, Microsoft, Navinfo, OpenStreetMap, TomTom

Attack Details

#1

A new toolset, called AlienFox, that attackers are using to compromise email and web hosting services. The toolkit is highly modular and frequently updated, with most of the tools being open source, which makes them easy for attackers to adapt to their needs. AlienFox primarily targets cloud-based and software-as-a-service email hosting services and primarily relies on server misconfigurations associated with popular web frameworks, including Laravel, Drupal, Joomla, Magento, Opencart, Prestashop, and WordPress.

#2

Attackers use the toolset to collect lists of misconfigured hosts and to extract sensitive information, including API keys and secrets, from configuration files exposed on victims' web servers. Later versions of the toolset add scripts that automate malicious actions using stolen credentials, including establishing Amazon Web Services (AWS) account persistence and privilege escalation and automating spam campaigns through victim accounts or services.

#3

AlienFox versions 2 through 4 have been identified to date, and the toolset is primarily distributed on Telegram in the form of source code archives, with some modules available on GitHub. The evolution of recurring features suggests the developers are becoming increasingly sophisticated, with performance considerations at the forefront in more recent versions.

Recommendations



Security Leaders

Phishing simulations and routine education and awareness training and communications rarely account for MFA fatigue and web browser hygiene. Integrate and communicate all lessons learned.



Security Engineers

- **Uni5 Users:** This is an actionable threat advisory in HivePro Uni5. Prioritize and block all indicators attributed to the threat actors and attacks through your Command Center. Test your controls with Uni5's Breach & Attack Simulation.
- **All Engineers:** Refer to and action upon the 'Potential MITRE ATT&CK TTPs' & 'Indicators of Compromise (IoC)' on the following pages.

Potential MITRE ATT&CK TTPs

<u>TA0001</u> Initial Access	<u>TA0002</u> Execution	<u>TA0003</u> Persistence	<u>TA0004</u> Privilege Escalation
<u>TA0005</u> Defense Evasion	<u>TA0006</u> Credential Access	<u>TA0007</u> Discovery	<u>TA0042</u> Resource Development
<u>TA0009</u> Collection	<u>TA0011</u> Command and Control	<u>T1586</u> Compromise Accounts	<u>T1059</u> Command and Scripting Interpreter
<u>T1068</u> Exploitation for Privilege Escalation	<u>T1003</u> OS Credential Dumping	<u>T1586.003</u> Cloud Accounts	<u>T1586.002</u> Email Accounts
<u>T1189</u> Drive-by Compromise	<u>T1110</u> Brute Force	<u>T1555</u> Credentials from Password Stores	<u>T1566</u> Phishing

Indicators of Compromise (IOCs)

TYPE	VALUE
SHA1	c0184407dcbec911a325d41e9a9ef1dbed524fe5 41a2cab42a08adf93b5ada1eafb75d5b4f496853 3cb5b4182ef6e8174f87c8ed3551f91b72c47370 17592a2fdb8dae9c4c88f1fbf7e9c632129f98df ab8d480c090ab8be0cdb0ff5bc0f59972845b125 15ade0df5b4e6a82ceec429a2673fd1ed011eb93 aa8be80db30c4f5a49c3e75254ef6d0101c37987 064734bc43ee2d83e8a275293d17fc925620bba1 9381c30e29089639249e67b62f61c6df4869c6c1 fd5228889cd12f343236f7d51c98fab4db6c4763 fd3375553dda2347c0b383d8e800bfe4f93d3af0 f4ef68d3d2b58a58a82e00ebeaaed556e03328af

TYPE	VALUE
SHA1	8e6e18ba7e251d31b46d17535010a8c583345b23 b3559eeac9a9caa840cc96980fe0bbd1c7da37d3 40df29a738fd5cab0face169d8a8426dff7d2d10 e663e24fc6aadbaae5bbf722a84097a6127f4066 c2f51b44e26e4aca40beb887ac4d36f3e091e26a 4266bdb139ae6d22ddf98501cc3af280aa488b42 329328dc57acece8c47ab5c73f7b9c7e4e09981a fc08c15dfd6074d80e1f8d777fb49f8c14b4af20 aa4672621f81f601882ad13f26d37dc8218bb06a 07289c56e65a98a85bc794374949aae98b819823 4ab401d4c490460fd457151f643b5ec7e594cd41 7848e53133f4470c29e33ee6dd87f8f326c5fa38 7d7bad6282531521b9103817a38bff3a34b89428 15129436f5bab6c3eea9b2dfc4d0f0043438e013 15aec55e56225700766d79b6fb9d212ccd21951 ebdc60f33d22c4256ca6ab4058059db1d618ec11 894fd799168f9ff11e74ee37d5bec35387feef24 28de7d7fcd18471f53737fd8a3df3a23a34cf758 3ddb8dc53b6151ea036db3d2a5f34e5f5b39e044 ceda47dd1aacc515d8bdda04299ab1ebf1ba0d73 23abd146befe761337e5155a116138acf81331d9 ac265c12a4f08378e2519e290b0c45a1adc7156f b8dc12cc600aced9d34c463c5bf5edb53db605fb 45a0675088afdcf2ec059510fc2a4905957c2a69 c3464926cf2075595c77dc5b3fbcf1f014c8046b fc0479a3d1188384613f437f28e28614a6118e94 5c9993e5d7468551c60e6dab488eccea7f4ef007 ece7e6727d2daa254e4d4a6be62744d6f3a2a2ef afb7b010bafb9f7faf2b528f128ff24da94e0190 959e377131762ccb879c36c53e3b71473d3b72fd 48afb7ac8fdf6a8da47601806a8028c61dad2eb7 23abd146befe761337e5155a116138acf81331d9 f5af939480fc86a086bc589047444b1c448ebb09 ac265c12a4f08378e2519e290b0c45a1adc7156f 0f1583b56dd02fc200c7dae0d3c9b32b4278846b 74c4cfa0edae5e87001c901214789cb0f0087031 ec5b2efe8eadfac7ceca545e25f06240bbf16960 9eb13d9a678cd2e78da41563b7461887ce5997b6 25bbda606c72e81fac9abe76e0f00f9cd12770e4 e786fc1fdcb7be28650383eb33cdf6c90f1d033

TYPE	VALUE
URLs	https://t[.]co/0LjXP5IJFn https://t[.]co/dxSqA1kGrF https://t[.]co/p2DVjbm0qj http://t[.]me/xMarvel_official https://rtvsmkqfa3clrvgj6f-9fd73c[.]ingress-daribow[.]easywp[.]com/wp-admin/v1/1[.]php https://t[.]me/xcatzechat https://t[.]me/tutorials_zone https://t[.]me/xxyz4 https://rtvsmkqfa3clrvgj6f-9fd73c[.]ingress-daribow[.]easywp[.]com https://reentry[.]co/3cii9/raw https://t[.]me/DailyTools https://t[.]me/exploi7 https://t[.]me/FoxCyberSecurity https://t[.]me/inscamwetrust0 https://t[.]me/official_xcatze https://t[.]me/sendgrid_aws_smtp https://t[.]me/Pegasus_Hub https://t[.]me/spamworldpro https://t[.]me/toxiarc

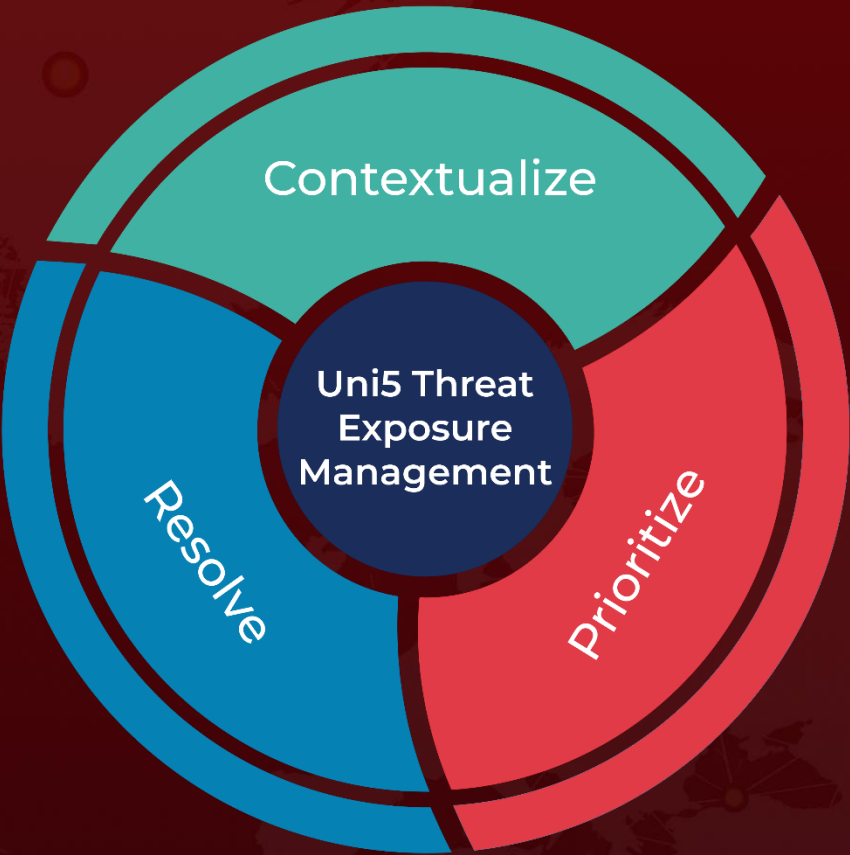
References

<https://www.sentinelone.com/labs/dissecting-alienfox-the-cloud-spammers-swiss-army-knife/>
https://assets.sentinelone.com/sentinellabs22/s1_-sentinellabs_dis#page=1

What Next?

At Hive Pro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with HivePro Uni5: Threat Exposure Management Platform.



REPORT GENERATED ON
April 04, 2023 • 2:25 AM

© 2023 All Rights are Reserved by HivePro



More at www.hivepro.com